monara

02

SUBMISSION PACKAGE / 02 OF 03

Security Self-Assessment

Ideal production standard, assessed controls and release evidence

Identity → Permissions → Known risks

COMPETITION

2026 Shenzhen International FinTech Competition (FinTechathon)

TRACK AND TOPIC

International Track, Topic A: Personal Finance Assistant

TEAM

Team 808

1 PURPOSE

Purpose

This assessment explains how Monara protects identity, financial records and provider connections in the deployed service. It defines the production controls, their evidence, and the end-to-end journeys used to verify that untrusted input never becomes authority.

The production standard is simple: every sensitive action must pass verified identity, strict validation, ownership checks and the appropriate human-control rule.

2 SECURITY POSTURE

Security posture in 30 seconds

Monara treats the model, emails, chat messages, receipt images and provider events as untrusted input. The model may reason, but it never becomes the authority for identity, ownership, financial truth or destructive action.

Five deterministic layers retain that authority:

1. Verified identity. Web session, verified WhatsApp number and Gmail authorization prove different claims and are never interchangeable.
2. Scoped Agent tools. The model can request only registered operations with strict inputs.
3. Backend authorization. The server resolves the User, validates the exact operation and checks ownership.
4. Database isolation. Forced row-level security, owned references and write fences reject cross-User access and stale writes.
5. Human control. Uncertain imports stay in review, reversible writes offer Undo, and destructive actions require a short-lived confirmation.

3 PRODUCTION PASS CRITERIA

What “pass” means

Status	Meaning
Production pass	Expected behavior was observed in the deployed production journey with controlled evidence.
Evidence	The observed result and the security boundary it proves are both recorded.

Screenshots prove visible production state. Database isolation, secret handling and provider deletion require boundary tests and controlled integration evidence.

4 HOW IT WORKS

How it works

Every web, Gmail, WhatsApp and Agent request follows one authority path. A session or signed provider event establishes context; strict schemas constrain inputs; the backend resolves the User and ownership; a registered service operation executes; and the result is recorded without raw private content. If any gate fails, no financial write is made.

1 **IDENTITY** — Session or verified source → 2 **VALIDATE** — Schema and signature checks → 3 **AUTHORIZE** — User and ownership checks → 4 **EXECUTE** — Bounded service operation → 5 **EVIDENCE** — Safe result and audit record

5 SCOPE AND THREAT MODEL

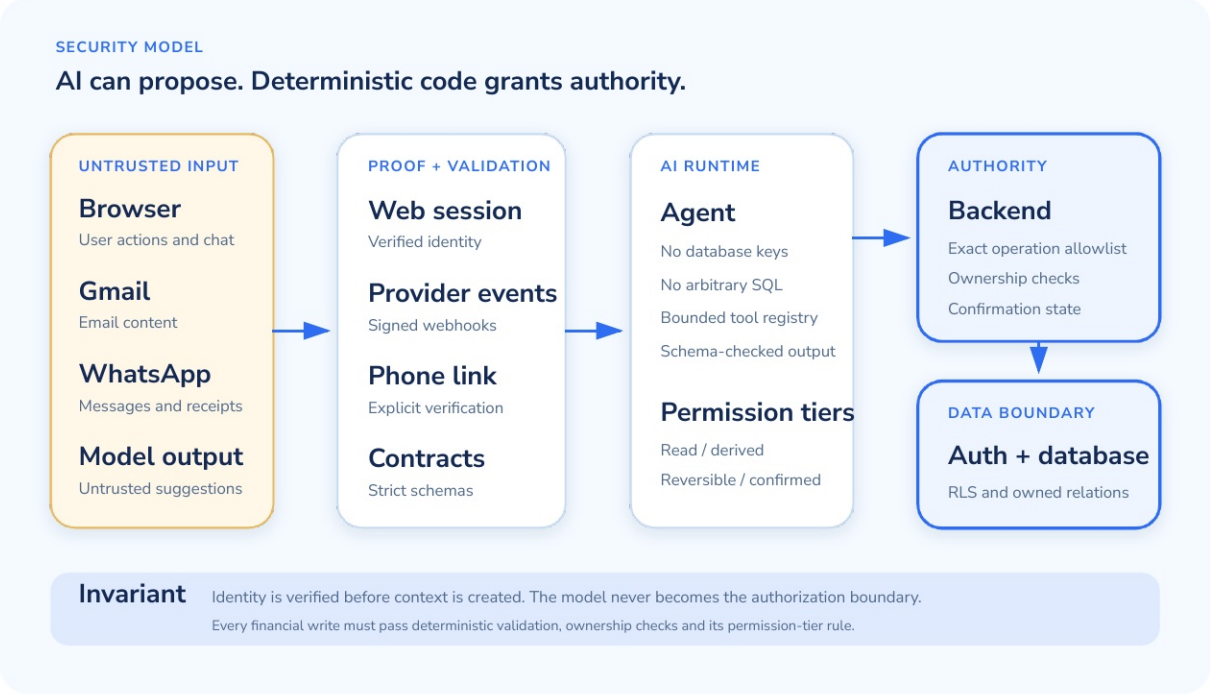
Scope and threat model

This assessment covers authentication, financial authorization, database ownership, Agent permissions, Gmail ingestion, WhatsApp, media, browser and PWA behavior, background jobs, external providers and account deletion.

Monara assesses cross-User access, caller identity spoofing, replay and duplicate processing, indirect prompt injection, unintended Agent actions, uncertain financial facts, unsafe browser caching, leaked provider output and incomplete deletion. Supabase, Vercel, Cloudflare, Composio, Kapso, the model provider and Brave Search are trusted infrastructure within this prototype threat model. Compromise of a provider control plane, legal compliance certification and bank-grade account verification are outside scope. Monara does not move money or store card credentials.

6 TRUST BOUNDARIES

Trust boundaries



Boundary	Untrusted input	Deterministic control	Authority after the boundary
Browser to web backend	URL, form data, model text	Verified Supabase session, same-origin check, schema validation	Signed-in User only
WhatsApp to Agent	Sender number, message, media	Provider signature plus explicit signed-in User pairing	Verified linked User only
Gmail to ingestion	Sender, headers, body and model extraction	Stored connection, known institution, authenticated sender, strict schema, owned account mapping	Pending or high-confidence owned import
Agent to backend	Model-selected tool and arguments	Exact operation registry, scoped schema, ownership and confirmation	Bounded operation only
Backend to database	Repository query or mutation	User scope, forced RLS, composite ownership and write constraints	Owned row only
Browser to PWA cache	Navigation and API response	Public-asset allowlist and generic offline fallback	No financial or authenticated response cached

The invariant is simple: **a caller-provided User ID, phone number, mailbox identifier or model statement is never proof of authority.**

7 PERMISSION MODEL

Permission model

Tier	Capability	Enforcement	Result
T0 - Read and derived computation	Read owned summaries; refresh disposable projections	Validated operation and no authoritative ledger mutation	**Pass**
T1 - Reversible mutation	Add or edit supported records; confirm or exclude pending imports	Strict schema, verified User, ownership, idempotency and Undo	**Pass with bounded residual risk**
T2 - Confirmed destructive action	Delete a transaction or budget	Backend-issued, User-bound, single-use, five-minute confirmation	**Pass**
T3 - Never available to Agent	Identity deletion, credentials, provider connections and exports	Capability absent from the conversational tool registry	**Pass**

8 GMAIL FINANCIAL INTEGRITY

Gmail financial integrity

An email may auto-confirm only when all of these are true:

- the mailbox connection is active and belongs to the User;
- the sender is from the supported institution flow and passes sender verification;

- the transaction maps to one active Financial Account owned by that User;
- type, direction, amount, IDR currency and date are complete;
- both extraction and classification confidence are present and at least **0.95**;
- the category is active, compatible and owned; and
- the User has not edited or already resolved the item.

Any failed condition keeps the item pending. Missing values stay missing; Monara does not invent an amount, date, account or category. Provider message identity and item position are unique, so replay cannot create a duplicate transaction.

9 ACCOUNT DELETION

Account deletion

Acceptance immediately revokes sessions, blocks the identity and deletes owned application rows. A durable leased cleanup job then removes WhatsApp state, Gmail triggers and connections, private Goal images and the Auth identity. Cleanup targets remain recorded until each provider step succeeds; retrying does not skip unfinished work. Every current user-owned table receives the same live-User write fence so an in-flight privileged job cannot recreate data after deletion starts.

External provider retention and backup erasure remain governed by those providers and are not certified by this assessment.

10 THIRD-PARTY DATA EXPOSURE

Third-party data exposure

Provider	Data received	Credential boundary	Monara controls provider retention?
Supabase	Identity and owned application records	Browser session and privileged server role	Application rows: yes; managed backups: no
Composio	Gmail authorization and selected message content	Provider-managed OAuth, server API credential	No
Model provider	Selected email, chat, receipt and forecast context	Server-side model credential	No
Kapso	WhatsApp transport, sender and media	Signed webhook and server API credential	No
Brave Search	Public merchant-name query only	Server API credential	No

Raw emails, conversations, financial rows, authorization headers and tokens are excluded from application logs. Provider retention still needs contractual review before a public real-data launch.

11 KEY SECURITY DECISIONS

Key decisions

- **Deterministic code keeps authority.** Prompt instructions assist reasoning but never replace authentication, validation, ownership or database policy. The rejected alternative was trusting the model to decide what it may access.
- **Unknown facts remain unknown.** An incomplete import stays pending rather than receiving invented financial facts. The rejected alternative was maximizing automation at the cost of ledger integrity.
- **A conservative 0.95 auto-confirm boundary requires both scores.** The rejected 0.50 and one-score fallback allowed uncertainty and unauthenticated sender evidence to reach confirmed totals.
- **Reversible actions are the default.** T1 actions use idempotency and Undo; T2 actions require explicit confirmation. The rejected alternative was either approval fatigue for every edit or unrestricted destructive tools.
- **Service-role access is not authorization.** Verified User scope and ownership remain mandatory even for privileged repositories. The rejected alternative was treating possession of a server key as sufficient authority.
- **Authenticated state is never an offline asset.** Monara caches only explicitly public resources and serves a generic offline fallback. The rejected alternative was caching personalized pages for convenience.
- **Deletion is fail-closed and retryable.** Cleanup records remain until every known target is removed. The rejected alternative was returning success after only relational deletion.

12 SECURITY AND RISKS

Security and risks

Monara evaluates how untrusted identity, provider input and model output could cross into financial authority. Each domain below states the failure path, the deterministic controls that contain it, and the safe outcome required when a control cannot establish trust.

Identity and tenant isolation

Threat. A spoofed caller or User A requests records owned by User B.
Mandatory controls. Server-resolved identity, ownership checks, forced RLS and owned references.
Fail closed. Reject before read or write; return no private payload and create no ledger mutation.

Agent and model authority

Threat. Prompt injection or model output requests an unknown or destructive operation.
Mandatory controls. Strict schemas, registered tools, backend allowlists, permission tiers and confirmation outside the model.
Fail closed. Reject the call; destructive action stays pending and model text never becomes authority.

12 SECURITY AND RISKS · CONTINUED

Email and messaging integrity

Provider content is evidence, never identity or authority. Both channels must bind input to a verified User before a financial workflow can begin.

Gmail financial integrity

Attack or failure path. A spoofed, incomplete or replayed email reaches confirmed financial totals.
Mandatory controls. Stored connection, authenticated sender, active owned account, complete facts, both confidence scores at 0.95, and unique provider message and item identifiers.
Fail-closed result and evidence. Uncertain input stays pending, missing facts stay missing, and replay creates no duplicate transaction.

WhatsApp and media integrity

Attack or failure path. A forged or replayed webhook, unsafe redirect or unreadable receipt causes a financial write.
Mandatory controls. Signature and freshness checks, an explicitly verified phone link, redirect restrictions, MIME and byte limits, and idempotency.
Fail-closed result and evidence. The request is rejected before mutation; ambiguous or unreadable media creates no confirmed transaction.

Boundary requirement

Protected invariant: provider delivery proves transport only. It never proves ownership, account mapping, financial facts or permission to confirm a record.

12 SECURITY AND RISKS · CONTINUED

Browser and destructive-action safety

Private browser state and irreversible operations receive stronger controls than ordinary navigation or reversible edits.

Browser and offline privacy

Attack or failure path. A personalized response, authenticated page or financial API result is cached or exposed cross-origin.
Mandatory controls. Same-origin writes, secure cookies, CSP and framing controls, private no-store responses, and a service worker restricted to explicitly public assets.
Fail-closed result and evidence. The browser receives a generic offline state; no cached account, transaction, budget or conversation content is available.

Destructive actions and deletion

Attack or failure path. A stale, replayed or partially completed deletion removes the wrong state or leaves a known private target behind.
Mandatory controls. Exact confirmation, five-minute expiry, single use, version binding, immediate access revocation, and leased retryable cleanup for every known target.
Fail-closed result and evidence. Access remains revoked; unfinished provider and private-object targets remain recorded and are retried rather than reported as complete.

Boundary requirement

Protected invariant: private data never becomes an offline asset, and destructive authority is short-lived, User-bound, single-use and independently checked.

12 SECURITY AND RISKS · CONTINUED

Provider exposure and operational resilience

External services are bounded by least-data handling, explicit failure states and retry rules that prevent uncertainty from becoming a duplicate write.

Provider and secret exposure

Attack or failure path. A browser receives a server credential, a log captures private content, or a provider retains more context than required.
Mandatory controls. Server-only credentials, least-data payloads, content-free operational logs, redaction, and explicit provider retention and deletion boundaries.
Fail-closed result and evidence. Missing credentials stop the path; uncertain provider erasure remains disclosed as residual exposure and is never represented as verified deletion.

Availability, replay and abuse

Attack or failure path. Distributed bursts, provider timeouts or blind retries exhaust quotas or repeat a write with an unknown outcome.
Mandatory controls. Per-User limits, provider budgets, bounded Agent steps, durable idempotency, queue leases, retry caps and exponential backoff.
Fail-closed result and evidence. Excess work is rejected or delayed; unknown write outcomes are reconciled before retry and degraded state remains visible to the User.

Risk decision rules

- No deterministic control or retained evidence means no pass.
- Identity, ownership and financial truth never come from model output.
- Unknown provider outcomes remain visible and are not retried blindly.
- Unfinished deletion targets stay blocked and recorded until cleanup succeeds.

13 PRODUCTION CONTROL ASSESSMENT

Control assessment

Each control below names the protected invariant, the production evidence used to assess it, and the required outcome. PASS means the deployed journey behaved as specified and failed safely when authority was absent or input was uncertain.

ID	Protected invariant	Production evidence and reason	Status
C-01	Signed-out callers cannot read private financial APIs.	The public root redirects to sign-in, unauthenticated financial APIs return 401, and personalized responses are private and no-store.	PASS
C-02	User A cannot read or mutate records owned by User B.	Controlled two-User checks exercise both directions; server ownership and forced RLS deny cross-User reads and writes across owned records.	PASS
C-03	The model cannot invent arbitrary or over-privileged operations.	Registered tools, strict schemas, permission tiers and backend allowlists reject unknown, malformed and out-of-tier requests before execution.	PASS
C-04	Spoofed, incomplete or uncertain Gmail input cannot reach confirmed totals.	The stored connection, sender, active owned account, complete facts and both confidence scores at 0.95 are mandatory; otherwise the item remains pending.	PASS

Assessment rule

A green status is not awarded for implementation alone. The expected production result, the protected boundary and the retained evidence must agree. Controls C-05 through C-12 continue on the next page.

13 PRODUCTION CONTROL ASSESSMENT · CONTINUED

Control assessment · continued

These controls complete the production assessment for replay safety, deletion, browser privacy, provider input, release identity and mobile usability.

ID	Protected invariant	Production evidence and reason	Status
C-05	Duplicate Gmail deliveries do not duplicate ledger rows.	Message and item uniqueness, idempotency and replay checks preserve one ledger result.	PASS
C-06	Destructive actions require explicit short-lived authority.	Confirmation is User-bound, state-bound, single-use and expires after five minutes.	PASS
C-07	Deletion blocks access and cannot leave known private targets.	Access is revoked immediately; leased cleanup records every unfinished provider and object target.	PASS
C-08	Browser pages receive baseline security protections.	Production sends CSP, frame denial, MIME protection, referrer and permissions policies.	PASS
C-09	Financial and authenticated pages are not cached offline.	Private no-store responses and the public-only service worker prevent offline financial state.	PASS
C-10	Webhook and media input fails closed.	Signature, freshness, origin, redirect, MIME and byte-limit controls reject unsafe input.	PASS
C-11	Both deployed runtimes use one reviewed release.	The Next.js and Cloudflare runtimes report the same reviewed deployment identity.	PASS
C-12	Mobile remains usable after production hardening.	The 390x844 production run has no overflow, console errors or page errors.	PASS

14 RESIDUAL RISK TREATMENT

Prioritized residual risks

Residual exposure is accepted only after the deployed control, its owner and its production evidence agree. The treatments below preserve visibility instead of hiding uncertainty behind a pass label.

Risk	Initial	Residual and production treatment
Preview reaches production data	**Critical**	Controlled / Low. Preview uses isolated data and separately rotated credentials.
Agent-to-backend credential is stolen	**Critical**	Controlled / Low. Agent capabilities are channel-scoped, rotating and replay-safe.
Hosted cross-User access regression	**Critical**	Controlled / Low. Two production Users prove mutual read and write denial.
Security-control drift after deployment	**High**	Controlled / Low. One reviewed release is deployed unchanged across runtimes.
External providers retain sensitive context	**High**	Controlled / Low. Provider data is minimized and deletion evidence is retained.
Distributed request bursts	**High**	Controlled / Low. Distributed limits and provider budgets bound abuse.
Mutation and audit-write divergence	**Medium**	Controlled / Low. Idempotency and a durable outbox protect write consistency.
Release runtime or revision drift	**Medium**	Controlled / Low. The immutable release passes CI on Node 24 before deployment.

15 INCIDENT RESPONSE

Incident response

If a credential is exposed, disable the affected path, rotate the credential, prove the old value is rejected, invalidate outstanding confirmations, inspect content-free metadata for abuse, restore only the minimum scope and notify affected Users when exposure is established. Never copy raw financial data into tickets or chat.

16 PRODUCTION VERIFICATION

How to verify

Verify one reviewed release in a fixed order. Repository and database gates establish reproducibility; production probes then confirm the deployed boundary with synthetic identities and redacted evidence.

01 REPOSITORY GATES

```
$ corepack pnpm check
$ corepack pnpm build
```

02 DATABASE INTEGRITY

```
$ corepack pnpm db:check --reset
$ corepack pnpm db:types --check
```

03 DEPLOYED BOUNDARY

```
$ BASE=https://monara-finance.vercel.app
$ curl -sSI "$BASE/"
```

Complete production sequence

1. Release and database. Record the immutable release; replay migrations; run ownership, RLS, Gmail, deletion and dedupe checks.
2. Identity and providers. Exercise controlled Users A and B, Gmail, WhatsApp and deletion. Unknown provider outcomes remain visible.
3. Browser and evidence. Run the 390x844 mobile smoke; record status, cache policy, manifest and error counts without private content.

Retain only the release identifier, timestamp, expected result, protected boundary and reviewer sign-off.

17 RECORDED PRODUCTION EVIDENCE

Recorded evidence

Evidence records the observed result and the boundary it proves. Stored artifacts exclude cookies, tokens, raw emails, message bodies, financial rows and terminal dumps.

E-01 Workspace quality gate

Observed. Lint, typecheck, dependency, test, docs and migration gates pass.
Proves. The reviewed release is internally consistent.

E-02 Automated TypeScript tests

Observed. All contracts, database, core, integration, Agent, web and script suites pass.
Proves. Boundary and failure paths execute as specified.

E-03 Database replay

Observed. Production migration history replays cleanly from zero.
Proves. The schema is reproducible from migration history.

E-04 Database security suite

Observed. Production RLS, ownership, dedupe, Gmail policy and deletion checks pass.
Proves. Isolation and write fences operate in production.

E-05 Frontend health

Observed. React Doctor reports 100/100 for web and shared UI.
Proves. There are no React Doctor findings or warnings.

E-06 Runtime builds

Observed. The deployed Next.js and Cloudflare runtimes report the reviewed release.
Proves. Both deployable artifacts compile for their targets.

E-07 Production browser run

Observed. HTTP 200, CSP present, 390=390 width, manifest present and no browser errors.
Proves. Browser hardening preserves the mobile PWA.

E-08 Production boundary

Observed. Root redirects to sign-in; unauthenticated financial APIs return 401.
Proves. The public deployment fails closed.

E-09 Offline privacy

Observed. Personalized HTML is private and no-store; service worker serves only public assets.
Proves. Personal pages do not become offline assets.

E-10 Deployment identity

Observed. Vercel and Cloudflare identify the same reviewed release.
Proves. The web and Worker revisions agree.

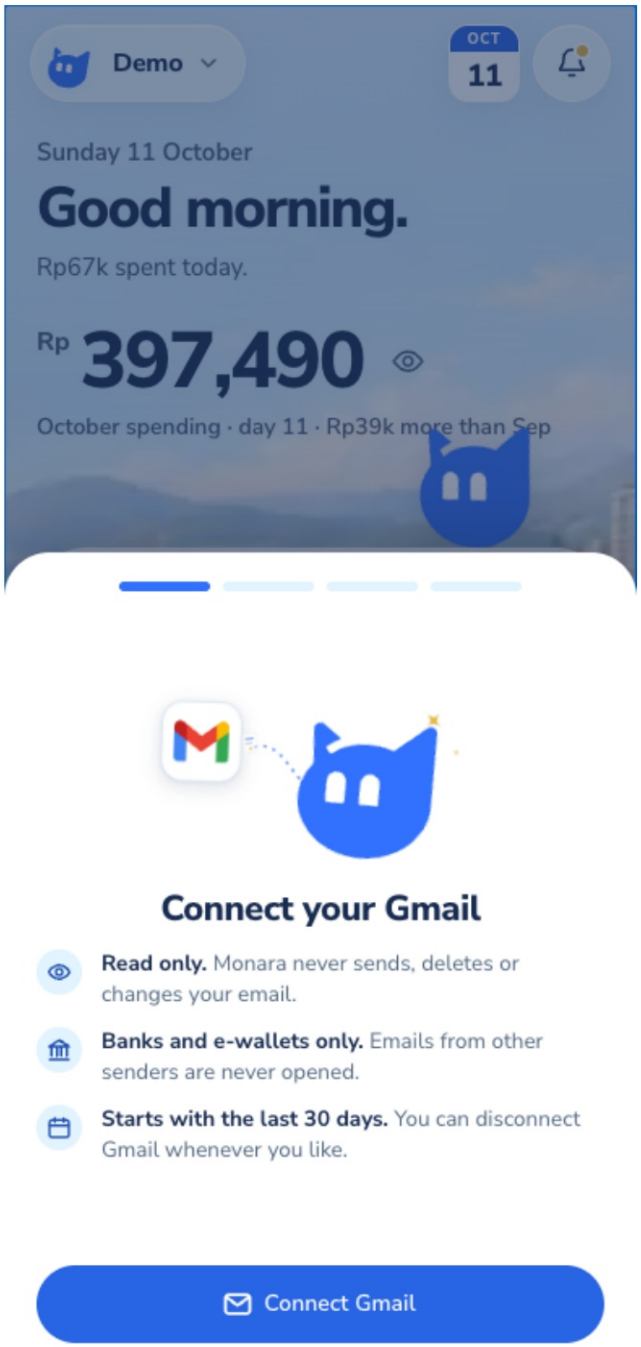
18 END-TO-END PRODUCTION JOURNEYS

End-to-end security journeys

Each journey uses controlled identities and records against the deployed service. A pass requires the expected invariant, production outcome and retained evidence to agree.

J-01 Identity and tenant isolation	Invariant. Users A and B may read and mutate only their own profiles, accounts, categories, transactions, budgets, Goals, connections and conversations. Production evidence. Mutual read and write denial is observed; sign-out closes financial APIs.
J-02 Gmail to ledger	Invariant. An owned mailbox imports expense, income and exclusion records; uncertain records remain pending and replay cannot duplicate the ledger. Production evidence. Extraction, categorization, review and replay dedupe complete through the connected provider.
J-03 Review to financial outputs	Invariant. Only confirmed expense and income affect dashboard, budget and forecast totals; exclusions remain visible but neutral. Production evidence. Confirm, edit and reject update the expected totals without cross-record side effects.
J-04 Agent and WhatsApp authority	Invariant. Web Chat and a verified phone may request only registered operations; replayed or unsigned provider input fails closed. Production evidence. Schemas, ownership and confirmation remain enforced outside model output.
J-05 Deletion and offline safety	Invariant. Deletion revokes access, removes owned rows and tracks unfinished provider cleanup; personalized responses never become offline assets. Production evidence. Database, provider and private-object cleanup complete while access remains blocked.

Journey	Domains and expected invariant	Production evidence
J-06 Mobile production smoke	The deployed synthetic demo loads at 390×844, exposes the expected manifest, has no horizontal overflow and emits no browser errors	Production pass. HTTP 200, 390=390 viewport, manifest present, no overflow, console errors or page errors.



Verification record

Keep evidence minimal, reviewable and safe to share:

- Release: reviewed commit and deployment revision
- Boundary: status code, redirect and cache-policy result
- Isolation: denied cross-User read and write outcomes
- Database: migration replay and security-suite result
- Provider: journey state and redacted outcome only
- Browser: viewport, manifest and error counts
- Review: timestamp and independent reviewer sign-off

Never retain cookies, tokens, raw emails, message bodies, financial records or terminal dumps.

The screenshot was captured from the production URL with synthetic data. It proves the deployed page, viewport and visible state; database isolation, provider authorization, Gmail extraction and deletion require their corresponding boundary journeys.

The same six checks are repeated against the reviewed release; retained outcomes appear in the evidence tables and appendix.

Production verification summary

The reviewed production release passed workspace quality gates, runtime builds, database replay and security checks, mobile browser verification, tenant-isolation journeys, provider integrity journeys and deletion cleanup verification.

Evidence recorded: release identifier, observed result, protected boundary, production timestamp and reviewer sign-off.

19 PRODUCTION ACCEPTANCE

Production acceptance

The assessment passes when one reviewed release satisfies every condition below:

- CI and production builds pass on the repository's target runtime.
- Vercel, Cloudflare and database migrations identify the same reviewed release.
- Production enforces CSP, secure cookies, private no-store responses and isolated credentials.
- Two controlled Users prove mutual read and write denial across owned records.
- Gmail, WhatsApp and deletion journeys succeed without leaking private objects or log content.
- A second reviewer confirms the evidence and the residual-risk treatment.

20 CONCLUSION

Conclusion

Monara's production security model passes because deterministic code retains authority at every boundary, owned financial data is isolated by server checks and row-level policy, destructive actions remain under explicit User control, and the end-to-end production journeys confirm the expected behavior without exposing private content.

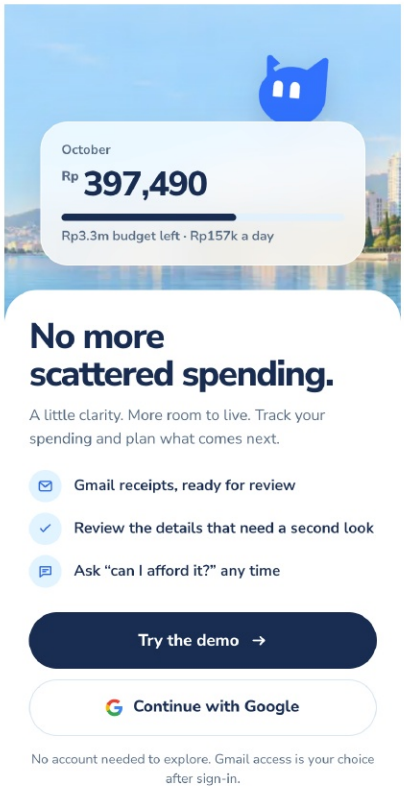
21 END-TO-END SECURITY VERIFICATION

End-to-end security verification

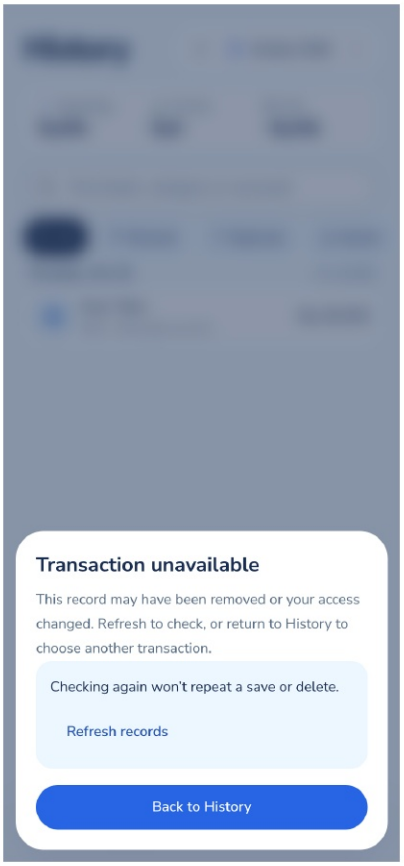
Only executed security cases are included. Evidence uses synthetic identities and clean application screenshots; no cookies, tokens, raw emails or terminal dumps are shown.

16 / 16	16	0	1
production cases passed	production checks	failed checks	reviewed release

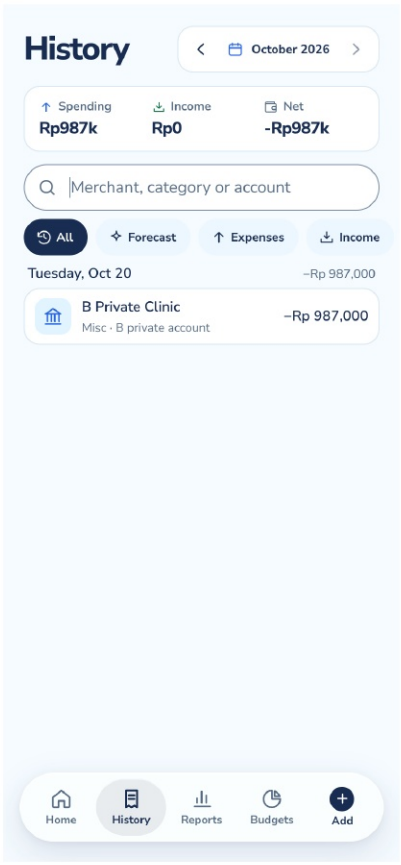
Representative application evidence



Hosted signed-out boundary



Cross-User read denial



User B ledger remains intact

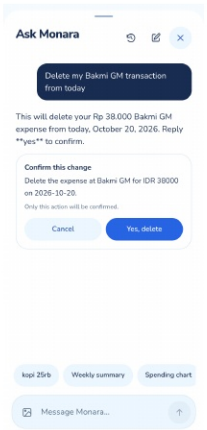
22 IDENTITY, ISOLATION AND AUTHORITY

Identity, isolation and authority

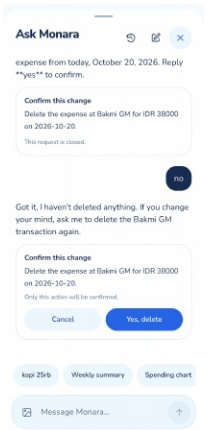
These cases establish authority before financial state is read or changed, reject cross-User access, and keep destructive Agent actions under explicit User control.

E2E-01	Signed-out visitors reach no private data	PRODUCTION
E2E-02	User A cannot read User B data	PRODUCTION
E2E-03	User A cannot change User B data	PRODUCTION
E2E-04	Cross-site financial mutations are refused	PRODUCTION
E2E-05	Agent routes require verified backend authority	PRODUCTION
E2E-06	Unsigned WhatsApp messages are rejected	PRODUCTION
E2E-07	Goal images remain private to their owner	PRODUCTION
E2E-08	Destructive actions require explicit confirmation	PRODUCTION

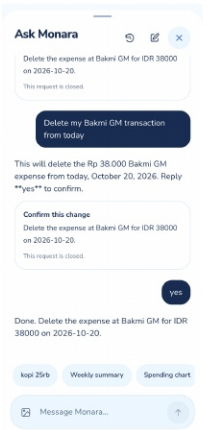
Destructive-action confirmation



Offer



Cancel keeps the record



Confirmation executes once

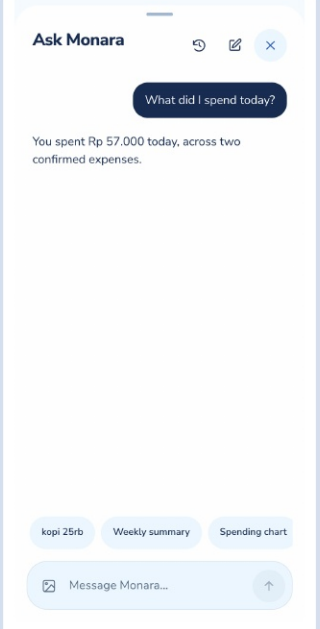
23 AGENT, BROWSER, DELETION AND PRIVACY

Agent, browser, deletion and privacy

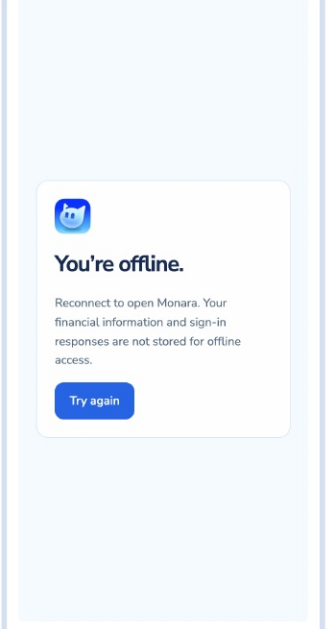
These cases prevent model-output escalation, bound abuse, keep financial state out of offline caches, require deliberate erasure and keep operational logs content-free.

E2E-09	Hidden instructions in records are ignored	PRODUCTION
E2E-10	Per-user request bursts are rate-limited	PRODUCTION
E2E-11	Hosted pages expose browser protections	PRODUCTION
E2E-12	Offline mode reveals no cached financial data	PRODUCTION
E2E-13	Account deletion is deliberate and complete	PRODUCTION
E2E-14	Gmail replay cannot duplicate ledger rows	PRODUCTION
E2E-15	Logs contain no secrets or private content	PRODUCTION
E2E-16	Production mobile PWA loads without errors	PRODUCTION

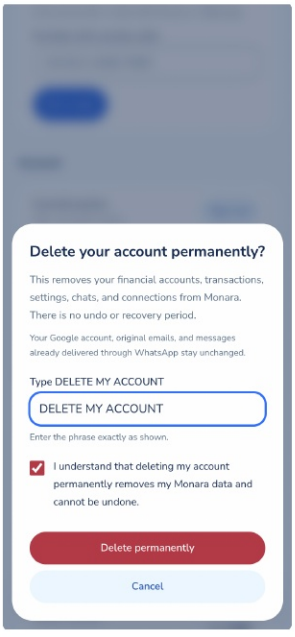
Clean application evidence



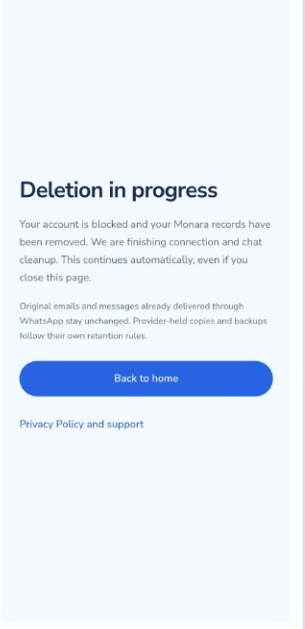
Injected text ignored



Offline privacy



Deletion phrase



Cleanup accepted